

# Incident Response Plan

Prepared by: Omkar Sawant

Client: GlobalTech Corp

Date: 1 June 2026

Project: Implementing a Secure Network Architecture for a Large Enterprise

Organisation: Spinnaker Analytics

## 1. Purpose and Scope

- This document defines the incident response plan for GlobalTech Corp, covering the procedures for detecting, containing, eradicating, and recovering from security incidents across all sites and systems.
- It also includes training materials and drill scenarios for the incident response team.
- This plan applies to all security incidents affecting GlobalTech Corp's network, systems, data, or operations
  - including but not limited to malware infections, data breaches, ransomware attacks, unauthorized access, denial of service, and insider threats.

## 2. Incident Response Team

### 2.1 Team Structure

| Role                 | Responsibility                                                 | Primary contact    | Backup contact          |
|----------------------|----------------------------------------------------------------|--------------------|-------------------------|
| Incident Commander   | Overall incident coordination and decision-making              | CISO               | IT Director             |
| Security Lead        | Technical investigation, containment, and eradication          | Security Manager   | Senior Security Analyst |
| Network Engineer     | Network isolation, firewall changes, traffic analysis          | Network Admin (HQ) | Network Admin (backup)  |
| System Administrator | Endpoint isolation, system recovery, backup restore            | Systems Admin      | IT Operations Lead      |
| Legal / Compliance   | Regulatory notifications, legal counsel, evidence preservation | Legal Counsel      | DPO                     |
| Communications Lead  | Internal and external communications, PR management            | HR Director        | CEO Office              |
| Executive Sponsor    | Board-level decisions, authorise major response actions        | CEO                | Board Chair             |

### 2.2 Escalation Thresholds

| Severity      | Definition                                                                        | Escalation                                        |
|---------------|-----------------------------------------------------------------------------------|---------------------------------------------------|
| P1 — Critical | Active breach, ransomware, data exfiltration in progress, production systems down | Incident Commander + CISO + CEO within 15 minutes |
| P2 — High     | Confirmed malware infection, compromised account, significant data at risk        | Security Lead + CISO within 30 minutes            |
| P3 — Medium   | Suspicious activity, policy violation, minor system anomaly                       | Security Lead within 2 hours                      |
| P4 — Low      | Informational alert, minor policy breach, no immediate risk                       | Security Analyst — track and monitor              |

### 3. Incident Response Lifecycle

- GlobalTech Corp follows the NIST SP 800-61 incident response lifecycle:
  - Preparation
    - → Detection & Analysis
      - → Containment
        - → Eradication
          - → Recovery
            - → Post-Incident Activity.

#### 3.1 Phase 1 : Preparation

- Preparation activities are conducted continuously before any incident occurs:
  - IR team trained and contacts documented
    - this plan reviewed and drilled quarterly
  - SIEM alerts configured and tuned
    - all detection rules tested (see Monitoring and Logging Plan)
  - Playbooks documented for common incident types
    - Ransomware
    - data breach
    - account compromise
    - DDoS
  - Forensic toolkit prepared
    - disk imaging tools
    - memory capture
    - log export scripts ready on IR jump box
  - Communication templates pre-drafted
    - internal notifications
    - customer notices
    - regulatory filings
  - Legal retainer in place
    - outside counsel available 24/7 for major incidents

## 3.2 Phase 2 : Detection and Analysis

- Incidents are detected through SIEM alerts, user reports, third-party notifications, or automated response triggers:

| Detection source         | Example                                         | Initial action                                  |
|--------------------------|-------------------------------------------------|-------------------------------------------------|
| SIEM alert               | C2 beaconing detected on 10.10.10.55            | Security analyst triages alert within 15 min    |
| User report              | Employee reports phishing email clicked         | Helpdesk escalates to security team immediately |
| EDR auto-response        | Wazuh isolates endpoint on ransomware detection | Security Lead notified, isolation confirmed     |
| Third-party notification | ISP reports DDoS traffic from GlobalTech IPs    | Network Engineer investigates and escalates     |
| Canary token alert       | Finance canary file accessed                    | Immediate P1 — Incident Commander notified      |

- Once detected, the analyst performs initial triage to determine severity, scope, and affected systems.
- All findings are logged in the incident ticket from the first moment of detection.

## 3.3 Phase 3 : Containment

- Containment prevents the incident from spreading.
- Short-term and long-term containment actions are taken in parallel:

### Short-term containment (within 30 minutes of P1/P2 detection):

- Isolate affected endpoint(s)
  - Wazuh active response or manual network block at core switch
- Block malicious IP/domain at NGFW
  - add deny rule and verify in SIEM logs
- Disable compromised user account
  - Entra ID account disable + revoke all active sessions
- Preserve evidence
  - take memory dump and disk image of affected systems before any changes

### Long-term containment (within 2 hours):

- Segment affected network zone
  - ACL changes to isolate compromised VLAN from rest of network
- Deploy additional monitoring on affected subnet
  - increase log verbosity, add packet capture
- Notify affected business units
  - work with communications lead on internal messaging

### 3.4 Phase 4 — Eradication

- Remove the threat from the environment completely before beginning recovery:
  - Identify root cause
    - How did the attacker get in?
    - Patch or configuration fix identified
  - Remove malware
    - run full EDR scan
    - remove malicious files
    - clean registry persistence mechanisms
  - Reset compromised credentials
    - all accounts that may have been exposed
    - not just confirmed compromised
  - Patch exploited vulnerability
    - emergency patch deployed
    - tested in staging first if time permits
  - Audit for additional compromised systems
    - threat actor may have moved laterally before detection
  - Verify eradication
    - rerun full SIEM search for indicators of compromise (IOCs) across all log sources

### 3.5 Phase 5 — Recovery

- Restore affected systems to normal operation safely:
  - Restore from clean backup
    - verify backup integrity before restore, confirm backup predates compromise

- Rebuild compromised systems
  - where integrity cannot be guaranteed, rebuild from known-good image
- Re-enable isolated endpoints
  - only after eradication confirmed, patch applied, and EDR reporting clean
- Restore network connectivity
  - remove temporary containment ACLs in stages, monitor closely
- Re-enable accounts
  - only after password reset and MFA re-registration completed
- Monitor intensively
  - elevated SIEM alerting for 72 hours post-recovery for signs of re-compromise

### 3.6 Phase 6 — Post-Incident Activity

- Conducted within 5 business days of incident closure:
  - Post-incident review (PIR) meeting
    - all IR team members
    - timeline reviewed
    - root cause confirmed
  - Lessons learned documented
    - what worked
    - what failed
    - what needs improvement
  - Action items assigned
    - security improvements
    - policy updates
    - training gaps addressed with owners and deadlines
  - Incident report finalised
    - full timeline
    - impact assessment
    - remediation actions
    - regulatory notifications
  - Update playbooks
    - incorporate new IOCs
    - Tactics
    - and lessons into relevant playbooks

## 4. Incident Playbooks

### 4.1 Ransomware Playbook

| Step | Action | Responsible | Timeframe |
|------|--------|-------------|-----------|
|------|--------|-------------|-----------|

|    |                                                                   |                    |            |
|----|-------------------------------------------------------------------|--------------------|------------|
| 1  | Wazuh auto-isolates infected endpoint                             | Automated (Wazuh)  | Immediate  |
| 2  | Security Lead notified — confirm isolation, assess scope          | Security Lead      | T+5 min    |
| 3  | Incident Commander activated — P1 declared                        | Incident Commander | T+15 min   |
| 4  | Block C2 IPs at NGFW — identify from SIEM IOC correlation         | Network Engineer   | T+20 min   |
| 5  | Identify blast radius — check lateral movement indicators in SIEM | Security Lead      | T+30 min   |
| 6  | Isolate affected VLAN if spread detected                          | Network Engineer   | T+35 min   |
| 7  | Preserve evidence — memory dump and disk image                    | Systems Admin      | T+40 min   |
| 8  | Notify Legal — assess GDPR/HIPAA notification obligations         | Legal/Compliance   | T+1 hour   |
| 9  | Begin eradication — clean or rebuild affected systems             | Systems Admin      | T+2 hours  |
| 10 | Restore from clean backup — verify integrity first                | Systems Admin      | T+4 hours  |
| 11 | Monitor for 72 hours — elevated SIEM alerting                     | Security Lead      | T+72 hours |
| 12 | Post-incident review and lessons learned                          | Incident Commander | T+5 days   |

## 4.2 Data Breach Playbook

| Step | Action                                          | Responsible      | Timeframe |
|------|-------------------------------------------------|------------------|-----------|
| 1    | Detect exfiltration — SIEM alert or user report | Security Analyst | Detection |

|    |                                                                      |                    |            |
|----|----------------------------------------------------------------------|--------------------|------------|
| 2  | Block exfiltration channel at NGFW                                   | Network Engineer   | T+15 min   |
| 3  | Identify data scope — what was accessed and exfiltrated              | Security Lead      | T+30 min   |
| 4  | Disable compromised account(s)                                       | IT Admin           | T+30 min   |
| 5  | Notify Legal — start GDPR 72-hour clock                              | Legal/Compliance   | T+1 hour   |
| 6  | Preserve evidence — logs, access records, exfil data if recoverable  | Security Lead      | T+1 hour   |
| 7  | GDPR notification to supervisory authority if personal data involved | DPO + Legal        | T+72 hours |
| 8  | Notify affected individuals if high risk to their rights             | DPO + Comms Lead   | T+72 hours |
| 9  | Remediate — patch vulnerability, strengthen controls                 | Security Lead      | T+1 week   |
| 10 | Post-incident review and report                                      | Incident Commander | T+5 days   |



## 5. Training and Drills

### 5.1 Training Programme

| Training type                                     | Audience                | Frequency                              |
|---------------------------------------------------|-------------------------|----------------------------------------|
| Security awareness — phishing, social engineering | All employees           | Annual + phishing simulation quarterly |
| IR team tabletop exercise                         | IR team members         | Quarterly                              |
| Technical IR skills — forensics, log analysis     | Security team           | Semi-annual                            |
| Ransomware drill — full simulation                | IR team + IT ops        | Semi-annual                            |
| Data breach notification drill                    | IR team + Legal + Comms | Annual                                 |
| Executive crisis communication                    | CISO + CEO + Comms Lead | Annual                                 |

### 5.2 Simulated Breach Drill Scenario — Network Compromise

- The following scenario is used for quarterly tabletop exercises.
- It simulates a realistic multi-stage attack against GlobalTech Corp:

#### Scenario: Operation Silent Pivot

| Stage | Attack phase          | Description                                                                               | IR team objective                                   |
|-------|-----------------------|-------------------------------------------------------------------------------------------|-----------------------------------------------------|
| 1     | Initial access        | Phishing email with malicious attachment opens reverse shell on employee laptop (VLAN 10) | Detect via EDR/SIEM, identify source                |
| 2     | Persistence           | Attacker installs scheduled task for persistence, exfiltrates credentials from browser    | Detect persistence via FIM, revoke credentials      |
| 3     | Lateral movement      | Attacker uses stolen credentials to move to Server VLAN via RDP                           | Detect via SIEM lateral movement rule, isolate      |
| 4     | Privilege escalation  | Attacker exploits misconfiguration to gain domain admin                                   | Detect via PIM audit log, revoke admin access       |
| 5     | Data exfiltration     | Attacker begins exfiltrating Finance data to external server                              | Detect via SIEM large transfer alert, block at NGFW |
| 6     | Ransomware deployment | Attacker deploys ransomware across file servers                                           | EDR auto-isolate, invoke ransomware playbook        |

- Discussion questions for the tabletop exercise:
  - At which stage would the SIEM have first generated an alert?
    - Was detection fast enough?
  - Which containment actions were most effective?
    - Which caused unnecessary business disruption?
  - Were regulatory notification timelines achievable given the incident timeline?
  - What security controls, if strengthened, would have prevented or limited the attack?
  - Were communication roles clear?
    - Did the right people have the right information at the right time?

### 5.3 Drill Evaluation Criteria

| Evaluation criterion     | Target                              | Measurement                          |
|--------------------------|-------------------------------------|--------------------------------------|
| Time to detect (P1)      | <15 minutes from initial compromise | SIEM alert timestamp vs attack start |
| Time to contain          | <30 minutes from detection          | Isolation confirmed timestamp        |
| Escalation accuracy      | Correct severity assigned           | Actual vs assigned severity          |
| Communication timeliness | CISO notified within 15 min of P1   | Notification log timestamp           |
| Evidence preservation    | Memory dump before any remediation  | Forensic artefact checklist complete |
| Regulatory awareness     | GDPR clock started within 1 hour    | Legal notification log               |

## 6. Regulatory Notification Contacts

| Regulation              | Notifying authority            | Contact / Portal                             |
|-------------------------|--------------------------------|----------------------------------------------|
| GDPR (India operations) | Data Protection Board of India | dpboard.gov.in — within 72 hours             |
| GDPR (EU operations)    | Relevant EU Member State DPA   | edpb.europa.eu — within 72 hours             |
| HIPAA (US clients)      | HHS Office for Civil Rights    | hhs.gov/hipaa — within 60 days               |
| IT Act 2000 (India)     | CERT-In                        | cert-in.org.in — within 6 hours of detection |

## 7. Summary

- The GlobalTech Corp Incident Response Plan provides a comprehensive framework for detecting, responding to, and recovering from security incidents. The plan includes:
  - 7-member IR team with defined roles, escalation thresholds, and 24/7 contact details
  - NIST SP 800-61 lifecycle
    - all 6 phases documented with specific actions and timeframes
  - 2 detailed playbooks
    - ransomware (12-step) and data breach (10-step) with owners and timeframes
  - Training programme
    - 6 training types including quarterly tabletop and semi-annual ransomware drills
  - Simulated breach scenario (Operation Silent Pivot)
    - 6-stage multi-vector attack for team exercises
  - Drill evaluation criteria
    - 6 measurable targets for assessing IR team readiness
  - Regulatory notification contacts
    - GDPR, HIPAA, IT Act 2000, with deadlines